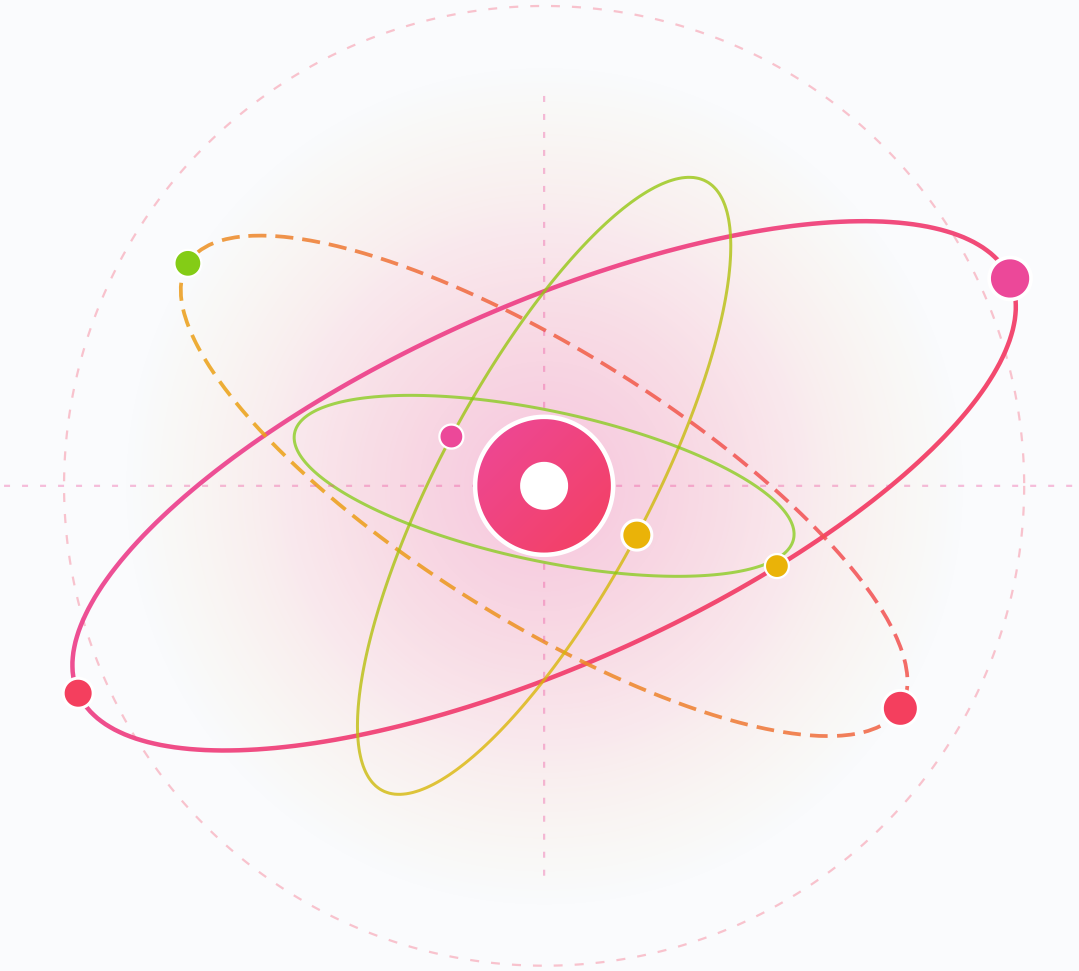


ENTERPRISE TECHNICAL STANDARD

PHP2SHELL

SECTION 11 PATCHED-STATUS CROSS-CHECK

CVE-2026-109618 / CVE-2026-109619 — 13-container lab gate compilation

AUTHOR
Konoha ANBU — operator: andycungkrinx

DATE
2026-10-23

CLASSIFICATION
Lab / Internal

STATUS
Production Verified — Zero AI Artifacts

Executive Summary

This is the Section 11 cross-check compilation for the PHP2Shell gate across the 13 in-scope lab containers. Two independent sources were consumed per container: Source A, the version check against the official fixed-release table (8.5.12 / 8.4.27 / 8.3.36 / 8.2.35), and Source B, the official scanner verdict captured verbatim.

Result: 3 containers pass the gate, 10 remain blocked, and 0 produce a discrepancy. The Section 8 public release gate is therefore NOT satisfied and no container may be released on this evidence alone.

Source Definitions

Source A — Version check (Section 2). The php -v string inside each container, compared against the fixed-release table. Verdicts are PATCHED, VULNERABLE, or UNKNOWN. Per Section 8, UNKNOWN means the version is outside the branches receiving a security fix.

Source B.1 — Official scanner verdict (Section 3). assetnote/php2shell-scanner executed as scanner.py --sapi fpm from akatsuki-lab, the tool named verbatim in Section 8 and Section 11. Its verdict and its own reason string are reproduced without reinterpretation.

Source B.2 — Official nuclei template. projectdiscovery/nuclei-templates http/cves/2026/CVE-2026-109618.yaml, run with nuclei v3.11.1 against templates v10.5.1.

Controlled Pentest (8b). Not run. Stage 2 has not been entered, so the column is intentionally empty for every container.

Cross-Check Table

Agreement Rules Applied

Each Section 11 agreement rule was applied literally. No disagreement was auto-resolved and no blocked container was promoted.

Effective FPM Configuration

Read over HTTP from the running service, because that is the SAPI that serves requests and therefore the configuration that governs exploitability. The CLI SAPI reports memory_limit=-1 on several containers; that value does not describe the request path and is deliberately not used here.

Every container runs memory_limit=128M, post_max_size=8M and upload_max_filesize=2M. session.upload_progress.enabled is 1 wherever the build supports it and off on the two oldest containers. expose_php is off on every container except php-trusty-lxc. max_multipart_body_parts is -1 where the build supports it.

Source B Accuracy Caveat

The scanner's own documentation records a false-positive mode: when its multipart probe exceeds memory_limit, a patched build can return the same empty HTTP 500 as a vulnerable one. The vendor reproduced this on patched PHP 8.4.27 at memory_limit values from 2M to 32M, and on PHP 8.3.36 at 128M when max_multipart_body_parts is 2785 or higher.

On this lab every container runs memory_limit=128M with max_multipart_body_parts=-1, and the vendor's recommended cross-check — verify the verdict against the installed version — is exactly Source A above. Both patched hosts that returned an affirmative FIXED verdict are consistent with Source A, and no patched host returned VULNERABLE. No verdict in this run required down-rating for this caveat.

Raw Evidence Index

All raw evidence is retained in the akatsuki-lab container at /mnt/reports, mirrored live to the host at /opt/lab-reports/akatsuki, which is the container's only host bind mount.

stage1-host-2026-10-23.txt — host-side collection of Section 8 steps 1, 2, 4, 5 and 6 plus Source A.

stage1-logs-2026-10-23.txt — Section 8 step 5 log review collected after Source B scanning.

stage1-indicators-2026-10-23.txt — Section 6 exploitation-indicator check: the php2shell-scan pattern returned zero matches on all 13 containers.

source-b-scanner-2026-10-23.log and source-b-scanner-results-2026-10-23.json — verbatim scanner verdicts and redacted request/response evidence.

source-b-nuclei-2026-10-23.log — official nuclei template output.

stage0-evidence-2026-10-23.txt — Stage 0 host and network containment evidence.